

SecureNorth Health — A Breach Waiting to Happen

You are not writing a student paper. You are stepping into the role of a **professional cybersecurity consulting firm** hired by a CISO to assess a real-world near-miss incident — and present your findings like your contract depends on it.

Key Logistics

- Due: **Week 13**
- Weight: **20% of final grade**
- Team Size: **3–4 members**
- Team Registration: **Week 7 deadline**

What You're Delivering

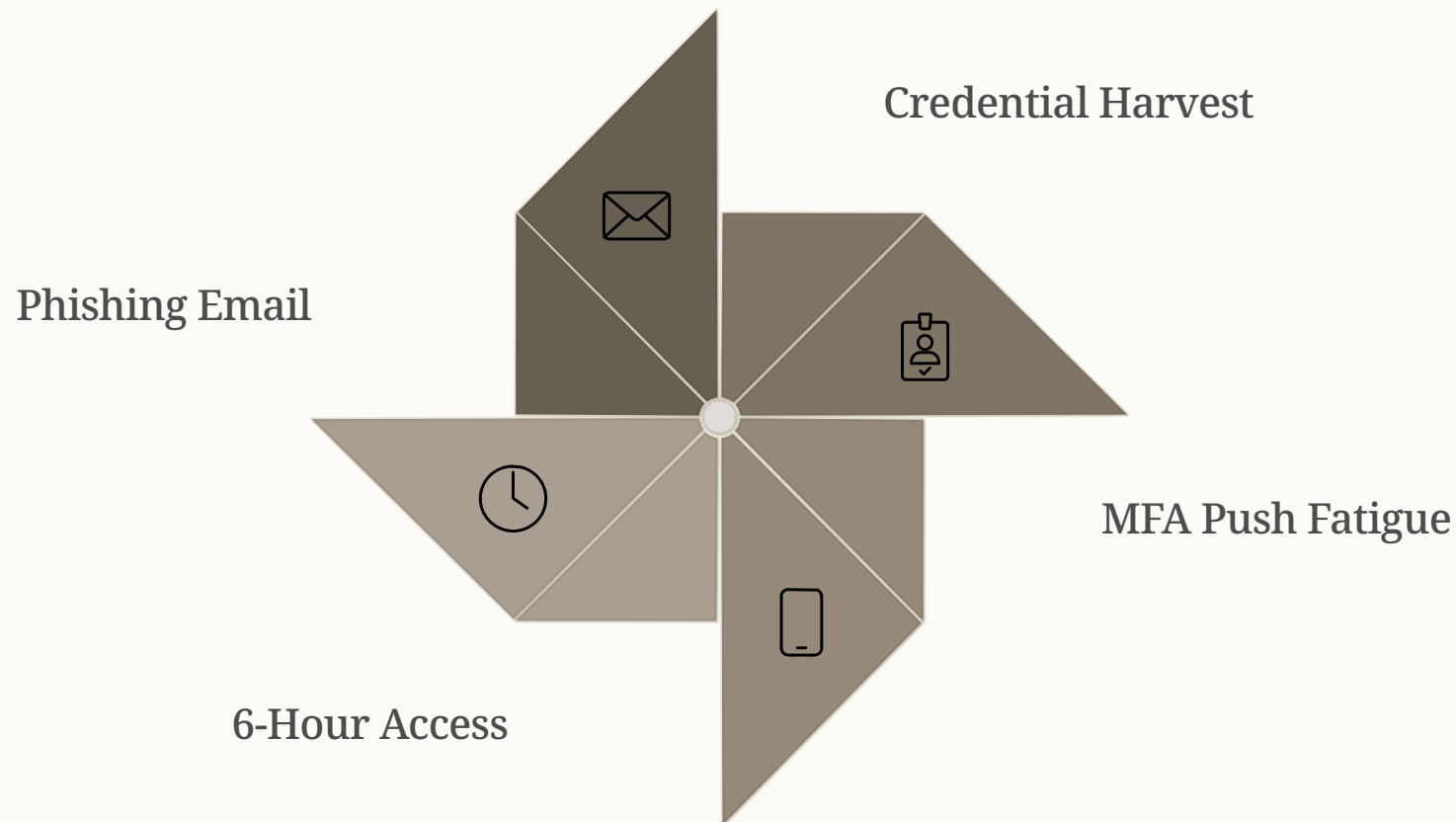
- A 15-minute recorded consulting presentation
- Coverage of 5 technical cybersecurity topics
- A live or recorded practical demonstration
- Equal speaking time from **every team member**

 Every team member must speak in the final video. Teams with silent members face grading penalties — no exceptions.

THE SCENARIO

Decoding the Near-Miss: What Happened at SecureNorth?

SecureNorth Health is a mid-sized healthcare network operating across three provinces. A routine phishing email triggered a chain of failures that gave an attacker **six hours of undetected access**. Your job is to treat every detail in the scenario as evidence — not background noise.



The attack didn't succeed because one nurse clicked a link. It succeeded because the environment was fragile beneath the surface. Use the scenario's facts to build a story about **systemic failure**, not individual error.



The Environment

- Flat network — no segmentation
- Expired SSL/TLS certificates
- Unpatched IoT devices (2021 firmware)
- Legacy VPN for remote staff
- Permissive, unreviewed cloud storage buckets



Consultant Mindset

Don't list these weaknesses — *narrate them*. Each vulnerability is a breadcrumb that leads to the next failure. Connect them into a coherent threat story that a CISO can act on.

Incident Analysis — The Core Breach

Your first technical topic requires a structured forensic lens. You must analyze what happened through three complementary frameworks: the CIA Triad, a root cause analysis, and a blast radius assessment of what *could* have occurred in those six hours.



CIA Triad Assessment

Map the incident explicitly: Which pillar was violated (Confidentiality)? Which was threatened (Integrity, Availability)? Be specific — cite which data or systems were at risk.



Root Cause Analysis

Go beyond the nurse's click. Analyze the **technical failures** of SMS MFA (SIM swapping, intercepts) and push notifications (MFA fatigue, social engineering). The human is the last line — why did every other line fail first?



Blast Radius

Six hours of undetected access on a flat network is catastrophic. What *could* have been exfiltrated, encrypted, or destroyed? Model the worst-case scenario to justify the urgency of your recommendations.

- ❏ The strongest presentations go beyond what happened — they model what *nearly* happened and use that to drive every recommendation that follows.

Encryption Audit — What's Broken and Why It Matters

SecureNorth has pockets of strong encryption — and glaring gaps. Your audit must be structured: identify what is broken, explain the real-world consequence, and propose a concrete fix. Integrate at least **two course case studies** to validate your analysis.

● Expired Certificates

Expired SSL/TLS leaves data in transit exposed to interception. Browsers and endpoints may silently fail validation. Recommend automated certificate lifecycle management (e.g., Let's Encrypt + monitoring).

● Unencrypted IoT Traffic

Medical IoT devices transmitting cleartext data are trivially interceptable on a flat network. Recommend device-level TLS enforcement and network isolation as a compensating control.

● Open Cloud Buckets

Research buckets with permissive ACLs expose potentially sensitive data publicly. Audit permissions immediately and enforce bucket-level encryption with access logging enabled.

● AES-256 Access Controls

The database uses strong encryption at rest — but the access control policies haven't been reviewed in **two years**. Strong encryption is useless if the wrong people hold the keys.

Structure your audit using a consistent framework: **What is broken** → **Why it matters** → **How to fix it**. This triad mirrors professional security advisory reports and will resonate with your CISO audience.

Authentication Redesign — Moving Beyond SMS and Push

The attack exploited two well-documented weaknesses in legacy MFA: SMS interception and push notification fatigue. Your redesign must propose a **phishing-resistant authentication architecture** — and prove it closes the exact attack vector that hit SecureNorth.

Why Legacy MFA Failed

- **SMS MFA:** Vulnerable to SIM swapping, SS7 protocol exploits, and real-time phishing proxies
- **Push Notifications:** Subject to MFA fatigue attacks — repeated prompts until the user approves
- Neither method verifies the *origin* of the authentication request

Phishing-Resistant Alternatives

- **FIDO2 / WebAuthn:** Cryptographically binds authentication to the legitimate domain — cloned login pages receive nothing
- **Hardware Security Keys (YubiKeys):** Physical possession required; immune to remote phishing
- **Passkeys:** Device-bound credentials with biometric verification

- ❏ Your presentation must explicitly contrast your proposed solution against the legacy SMS/Push setup. Show the CISO — step by step — why a cloned login page cannot harvest a FIDO2 credential.

Zero Trust Architecture — Redesigning the Network

SecureNorth's flat network meant that once inside, the attacker faced *no internal barriers*. A Zero Trust Architecture (ZTA) proposal must replace implicit trust with continuous verification — and you must illustrate this with a clear network diagram showing the before and after.



Identity Verification

Every access request — internal or external — must be authenticated and authorized. No user or device is trusted by default, regardless of network location.



Least Privilege Access

Users and systems receive only the minimum permissions required. Clinical staff cannot reach admin systems; IoT devices cannot reach patient records.



Device Posture Checks

Before granting access, validate device health: patch status, endpoint detection presence, and compliance with organizational policy. Non-compliant devices are quarantined.



Micro-Segmentation

Separate VLANs or segments for Clinical, Administrative, and IoT traffic. A compromised IoT device cannot pivot to an EMR database in a segmented environment.



Your slide deck **must** include a high-level network diagram: flat network (before) vs. segmented ZTA (after). Also address how Zero Trust replaces the legacy VPN for remote staff — this is a specific scenario detail you cannot skip.

IoT & Cloud Risk Summary — A Structured Threat Matrix

Your final technical topic requires you to identify at least **two IoT risks** and **two cloud risks**, assess their healthcare impact, and recommend specific controls. Present this as a structured matrix — readability signals consulting maturity.

Threat	Asset at Risk	Healthcare Impact	Recommended Control
🔊 Legacy 2021 IoT Firmware	Medical monitoring devices	Device tampering; false patient readings	Patch/replace; network isolation per device class
📶 IoT Cleartext Traffic	Device-to-server telemetry	Interception of vitals data; HIPAA violation risk	Enforce TLS; deploy IoT-specific firewall rules
☁️ Permissive Cloud Buckets	Research and clinical data stores	Public exposure of patient records	Audit ACLs; enforce private-by-default policy
🔑 Unreviewed DB Permissions	AES-256 encrypted database	Insider threat; unauthorized data access	Quarterly access reviews; role-based access control

Frame every impact through a **healthcare lens** — patient data exposure, medical device reliability, and regulatory consequence (HIPAA, PHIPA) carry far more weight with a CISO than generic technical risk language.

Choose Your Demonstration — Make It Count

The practical demonstration is your team's opportunity to prove technical hands-on competence, not just theoretical knowledge. Pick the option that aligns with your team's strengths. You will be graded on how well you can **explain every step** — not just show it working.

Option A — Cryptography

Python + AES-256-GCM. Demonstrate encryption and decryption of a sample healthcare record. Then show what happens when ciphertext is tampered with — authentication tag failure. Explain each function call.

Option B — Authentication

FIDO2 / WebAuthn / Passkey. Walk through a full registration and login flow in a test environment. Demonstrate why a cloned phishing page cannot intercept the credential. Explain the underlying cryptographic binding.

Option C — Network Segmentation

Cisco Packet Tracer. Build a simulation with separate VLANs for IoT, Clinical, and Admin. Demonstrate a simulated compromise attempt that is blocked at the segment boundary. Explain the ACL and VLAN configuration.

 **AI Policy — Critical:** You may use AI tools to help write code or configurations. However, you **must** be able to explain every single line on camera. If you cannot explain it, do not submit it. Unexplained AI output will result in academic integrity review.

Submission Requirements & Production Standards

Your final submission has two components — a recorded video and a slide deck. Both must meet professional standards. Sloppy production signals a sloppy consulting firm, and that affects your grade.



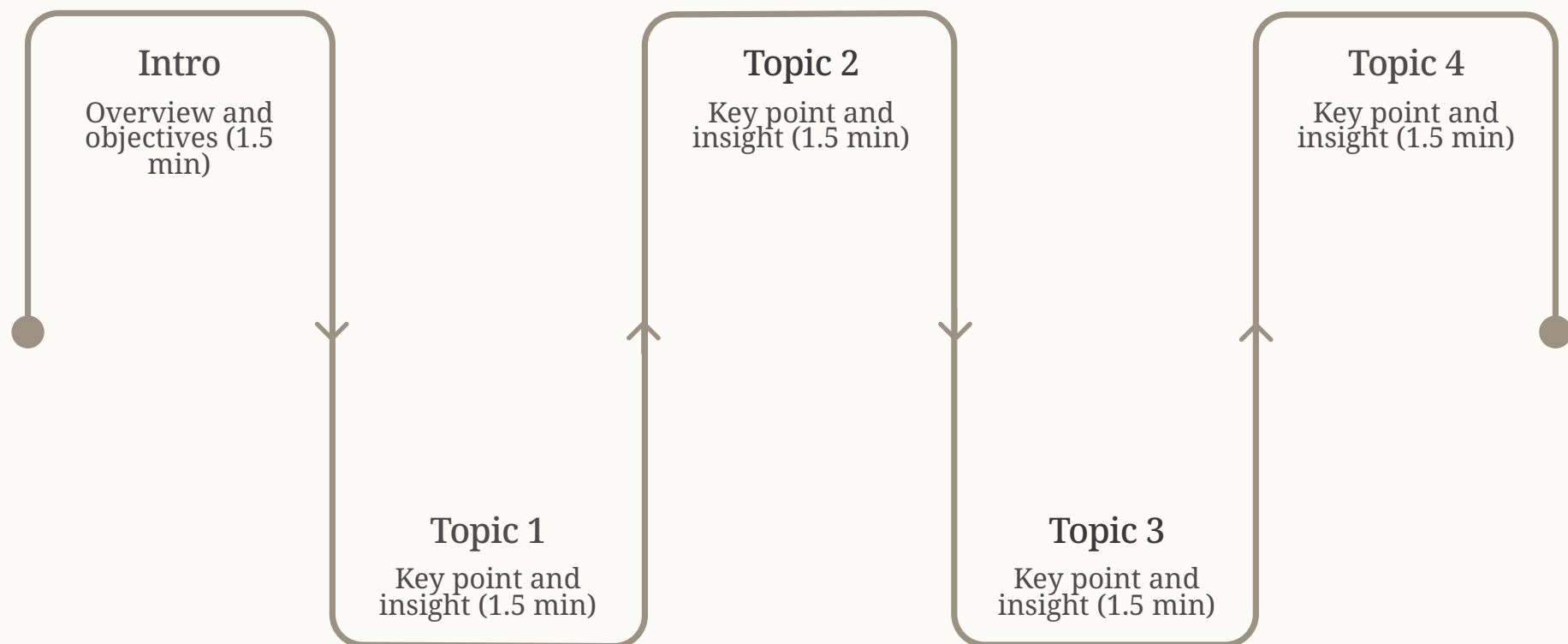
What to Submit

- **Video:** 15-minute MP4 file (or streaming link)
- **Slide Deck:** PDF or PPTX format
- Both submitted together by the Week 13 deadline



Production Standards

- **Time:** Hard 15-minute maximum — practice your pacing
- **Participation:** Every member speaks for roughly equal time
- **AI Policy:** No AI-generated scripts or slide text permitted
- **Slides:** Support your speech — don't replicate it verbatim



Fifteen minutes divided across five topics plus a live demonstration means roughly **1.5 to 2 minutes per topic**. Practice your transitions between speakers — a smooth handoff is a hallmark of a professional consulting team.

Keys to an "A" Grade — What the Grader Is Looking For

The rubric rewards **depth, demonstration, and delivery** in equal measure across three weighted categories. Understanding how points are distributed lets your team allocate preparation time strategically.

60%	20%	20%
Technical Depth	The Demo	Professional Delivery
Accurate, detailed analysis of all five core topics. Surface-level bullet points don't earn this — nuanced, connected reasoning does.	A flawless, well-explained walkthrough. Examiners want to see that your team can <i>do</i> the work, not just describe it.	Clean slides, no reading from a script, smooth speaker transitions, and consistent professionalism throughout the recording.

Your Immediate Next Steps

01	02	03
Form Your Team	Select Your Demo Option	Register by Week 7
Identify 2–3 peers whose strengths complement yours — especially for the demo option you plan to select.	Align early. Option A, B, or C — choose based on your team's genuine technical skills, not convenience.	Team registration closes Week 7. Missing this deadline may affect your ability to submit as a team.

☐ Your slides should support your presentation — not act as a teleprompter. If a sentence is on your slide, you should be *expanding* on it verbally, not reading it aloud. Practice as a team until your delivery feels like a cohesive consulting pitch.